

Scanning Issues

Nessus is a well-known and widely used vulnerability scanning platform. However, a few best practices should be taken into consideration before starting a scan. Scans can cause issues on sensitive networks and provide false positives, no results, or have an unfavorable impact on the network. It is always best to communicate with your client (or internal stakeholders if running a scan against your own network) on whether any sensitive/legacy hosts should be excluded from the scan or if any high priority/high availability hosts should be scanned separately, outside of regular business hours, or with different scan configurations to avoid potential issues.

There are also times when a scan may return unexpected results and need to be fine-tuned.

Mitigating Issues

Some firewalls will cause us to receive scan results showing either all ports open or no ports open. If this happens, a quick fix is often to configure an Advanced Scan and disable the **Ping the remote host** option. This will stop the scan from using ICMP to verify that the host is "live" and instead proceed with the scan. Some firewalls may return an "ICMP Unreachable" message that Nessus will interpret as a live host and provide many false-positive informational findings.

In sensitive networks, we can use rate-limiting to minimize impact. For example, we can adjust **Performance Options** and modify **Max Concurrent Checks Per Host** if the target host is often under heavy load, such as a widely used web application. This will limit the number of plugins used concurrently against the host.

We can avoid scanning legacy systems and choose the option not to scan printers, as we showed in an earlier section. If a host is of particular concern, it should be left out of the target scope as Nessus does not have an option for an "exclusion list" of hosts within a CIDR range like we can do with tools like Nmap.

Finally, unless specifically requested, we should never perform **Denial of Service checks**. We can ensure that these types of plugins are not used by always enabling the **"safe checks"** option when performing scans to avoid any network plugins that can have a negative impact on a target, such as crashing a network daemon. Enabling the "safe checks" option does not guarantee that a Nessus vulnerability scan will have zero adverse impact but will significantly minimize potential impact and decrease scanning time.

It is always best to communicate with our clients or internal stakeholders and alert necessary personnel before starting a scan. When the scan is completed, we should keep detailed logs of the scanning activity in case an incident occurs that must be investigated.

Network Impact

It is also essential to keep in mind the potential impact of vulnerability scanning on a network, especially on low bandwidth or congested links. This can be measured using **vnstat**:

```
dbcypth0n@htb[/htb]$ sudo apt install vnstat
```

Let's monitor the **eth0** network adapter before running a Nessus scan:

```
dbcyph0n@htb[/htb]$ sudo vnstat -l -i eth0

Monitoring eth0...    (press CTRL-C to stop)

  rx:      332 bit/s      0 p/s      tx:      332 bit/s      0 p/s

  rx:      0 bit/s      0 p/s      tx:      0 bit/s      0 p/s
  rx:      0 bit/s      0 p/s      tx:      0 bit/s      0 p/s^C

eth0 /  traffic statistics

-----+-----
      rx      |      tx
-----+-----
bytes      572 B |      392 B
-----+-----
      max      |      332 bit/s
      average    |      78 bit/s
      min        |      0 bit/s
-----+-----
packets      8 |      5
-----+-----
      max      |      0 p/s
      average    |      0 p/s
      min        |      0 p/s
-----+-----
time                40 seconds
```

We can compare this result with the result we get when monitoring the same interface during a Nessus scan against just one host:

```
dbcyph0n@htb[/htb]$ sudo vnstat -l -i eth0

Monitoring eth0...    (press CTRL-C to stop)

  rx:   307.92 kbit/s   641 p/s      tx:   380.41 kbit/s   767 p/s^C

eth0 /  traffic statistics

-----+-----
      rx      |      tx
-----+-----
bytes      1.04 MiB |      1.34 MiB
-----+-----
      max      |   480.59 kbit/s
      average    |   296.72 kbit/s
      min        |      0 bit/s
-----+-----
packets   18252 |   22733
-----+-----
      max      |   969 p/s
      average    |   598 p/s
      min        |      0 p/s
-----+-----
time                38 seconds

real  0m38.588s
user  0m0.002s
sys   0m0.016s
```

When comparing the results, we can see that the number of bytes and packets transferred during a vulnerability scan is quite significant and can severely impact a network if not tuned properly or performed against fragile/sensitive devices.

[< Previous](#)[Next >](#)[✔ Mark Complete & Next](#)

Table of Contents

Security Assessments

Security Assessments	✓
Vulnerability Assessment	✓
Assessment Standards	✓

Vulnerability Scoring and Reporting

Common Vulnerability Scoring System (CVSS)	✓
Common Vulnerabilities and Exposures (CVE)	✓

Nessus

Vulnerability Scanning Overview	✓
Getting Started with Nessus	✓
Nessus Scan	✓
Advanced Settings	✓
Working with Nessus Scan Output	✓

Scanning Issues

🔒 Nessus Skills Assessment

OpenVAS

Getting Started with OpenVAS
OpenVAS Scan
Exporting The Results
🔒 OpenVAS Skills Assessment

Reporting

Reporting

My Workstation

O F F L I N E

▶ Start Instance

∞ / 1 spawns left